

W12D4 - Scansione iniziale

Studente: Riccardo Luzzi

Corso: Cyber Security

Sistema utilizzato: Kali Linux

Strumenti utilizzati: Nessus Essentials, Nmap, Netcat, showmount, VirtualBox, pfSense

Target: Metasploitable - 192.168.51.101

Scenario di rete: Kali/Nessus e Metasploitable su reti differenti, con instradamento tramite pfSense

1. Obiettivo della scansione iniziale

Prima di applicare le modifiche ho utilizzato la Basic Network Scan già eseguita sul target Metasploitable come riferimento iniziale. La scansione aveva prodotto 86 finding raggruppati e mostrava diverse vulnerabilità Critical e High, coerenti con la natura volutamente vulnerabile della macchina di laboratorio.

Per l'esercizio W12D4 ho preso come riferimento i quattro finding indicati nella traccia. Nella mia scansione il problema NFS compariva però come NFS Shares World Readable (High), e non come NFS Exported Share Information Disclosure (Critical): l'evidenza tecnica era comunque l'export della directory root verso tutti gli host (/ *). Ho quindi applicato la remediation al finding effettivamente rilevato. Come prova facoltativa ho inoltre scelto rlogin Service Detection, mitigandolo tramite una regola firewall su pfSense.

Figura 1 - Riepilogo della scansione Nessus iniziale sul target 192.168.51.101

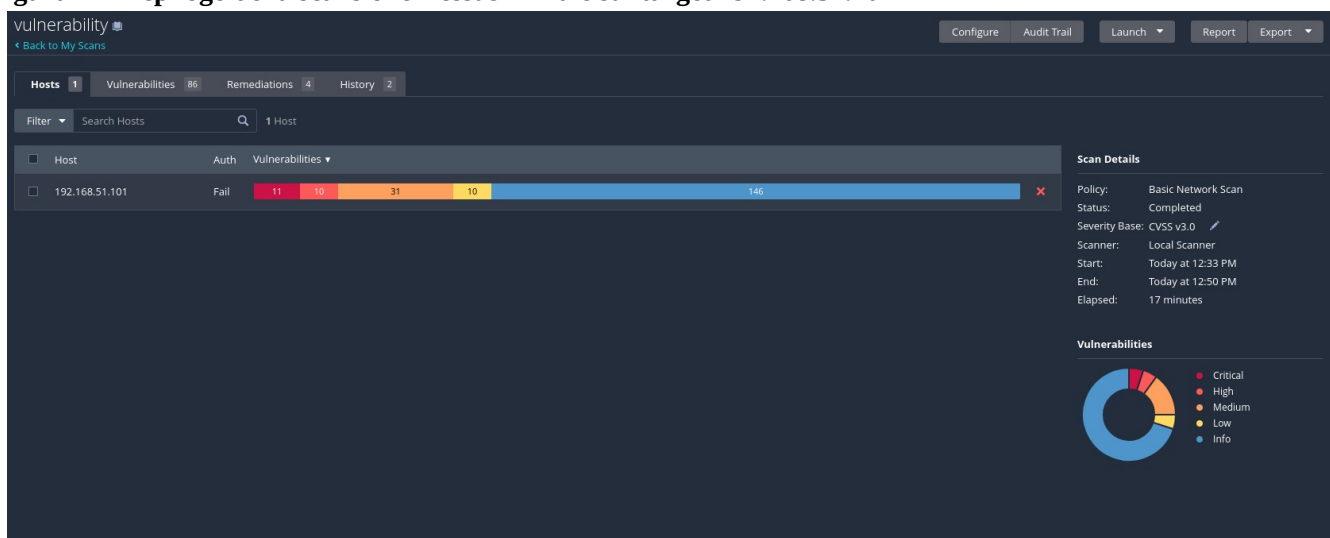
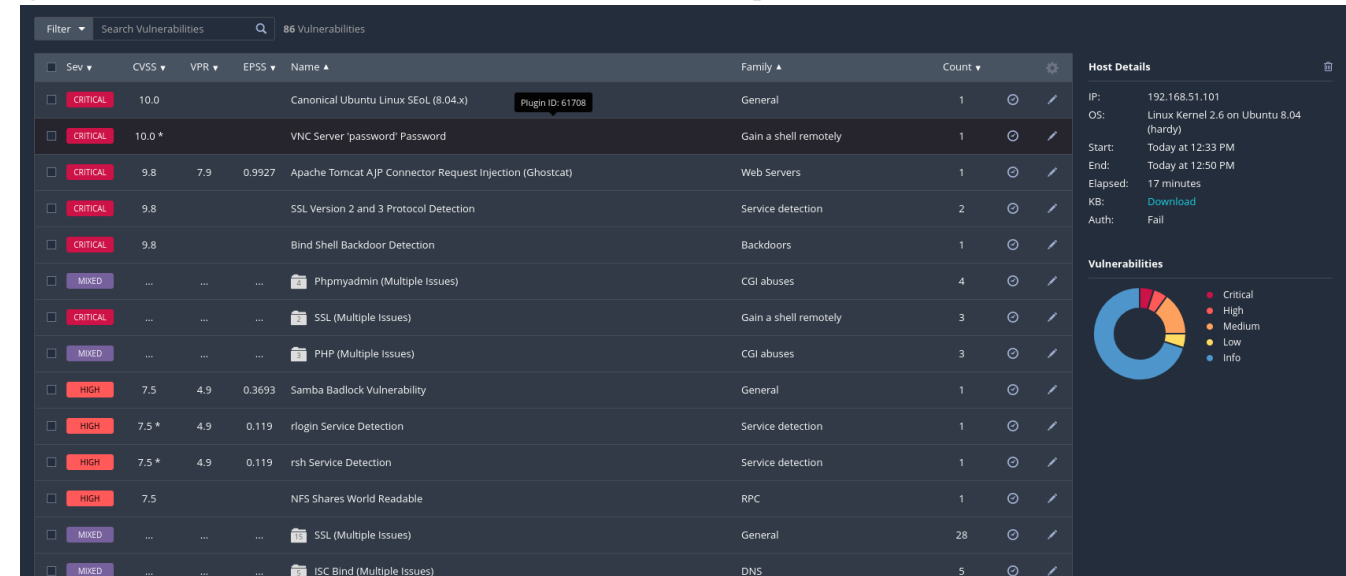


Figura 2 - Prime vulnerabilità della scansione iniziale ordinate per severità



2. Vulnerabilità selezionate per la remediation

Finding	Severità	Porta/e	Intervento previsto
NFS Shares World Readable	High	111, 2049/TCP	Rimuovere l’export NFS della root esposto a tutti gli host.
rexecd Service Detection	Critical	512/TCP	Disabilitare il servizio rexecd gestito da xinetd.
VNC Server 'password' Password	Critical	5900/TCP	Sostituire la password debole mantenendo attivo il servizio VNC.
Bind Shell Backdoor Detection	Critical	1524/TCP	Disabilitare la bind shell configurata tramite xinetd.
rlogin Service Detection (facoltativa)	High	513/TCP	Limitare l’esposizione con una regola di blocco su pfSense.

Figura 3 - Finding indicati nella traccia del progetto; nella scansione reale il problema NFS era riportato come NFS Shares World Readable

